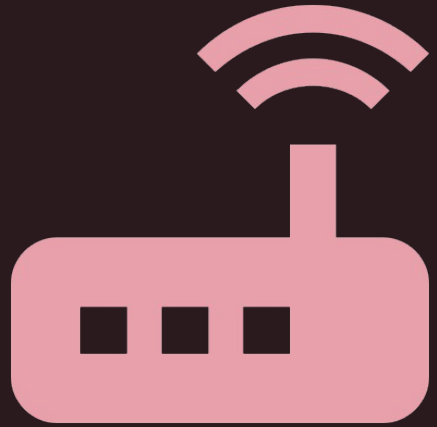
Higher National Diploma in Network Engineering, Year 2
BSc (Hons) Ethical Hacking & Network Security, Year 2

PRINCIPLES OF INFORMATION SECURITY

Networks: threats and defences



Day 8 - Morning

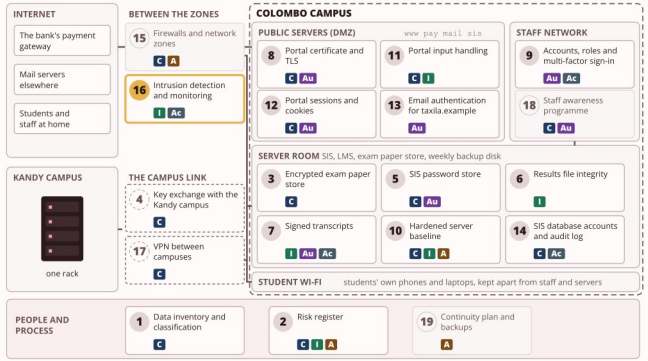
Running case: Taxila College, a fictional college

Niranga Dharmaratna
School of Computing & Engineering
National Institute of Business Management

Today

What a shared network shows, and how firewalls and zones contain trouble.

- Sniffing and traffic analysis - 35 min
- Scanning and reconnaissance - 30 min
- Interception and address poisoning - 30 min
- Firewalls and intrusion systems - 30 min
- Zones, private tunnels and depth - 30 min



TODAY

16 Intrusion detection and monitoring

17 VPN between campuses

Today serves two outcomes

LO1 Explain the fundamentals of information security.

LO2 Discuss the key characteristics of cryptography and cryptographic systems.

LO3 Analyze the principles of encryption, decryption, hashing, and data integrity.

LO4 Outline the process of ensuring digital security.

LO5 Describe the fundamentals of threats and countermeasures.

LO6 Explain the fundamentals and process of business continuity planning.

Where we start

RECALL

Transport security makes web traffic unreadable to anyone on the path.

- **Defence in depth** stacks independent controls
- A hardened server runs only what it **needs**
- A **certificate** proves which server you reached

Today the same ideas meet the network itself.

Thousands of devices, one Wi-Fi

- Thousands of phones and laptops join the **student Wi-Fi** every day
- The college manages **none** of them
- A report shows a server door open to that Wi-Fi

T TAXILA

Student Wi-Fi kept apart from staff and servers; someone notices when something unusual happens.



HEAD OF IT

Before we buy anything, let us see what can be seen, and what can be reached.

The Head of IT, on the eighth day of your placement.

CONCEPT 1

Sniffing and traffic analysis

The student wireless network carries readable traffic unless the service uses secure connections.

TRY IT FIRST

Unencrypted traffic is readable on a shared segment; encrypted is opaque.

35 min

Demonstration: the glass wall

1. Open the plain-web capture and read the form packet
2. Find the index number in plain text
3. Open the secure-web capture and look for it again
4. Mark what a watcher can still read

Encryption hides the content, not the conversation.

Sniffing and traffic analysis

- On a shared segment every machine can **receive** what others send
- **Sniffing** reads that traffic as it passes
- Unencrypted content is **readable**: passwords, cookies, messages
- Encrypted traffic still shows who, when, which port and how much
- **Traffic analysis** reads those patterns without the content

A conversation in a shared room

YOU ALREADY KNOW THIS

Two people talk out loud in a shared room. A sealed note hides the words, not who passed it.

MAPPING

anyone hearing the words = any machine reading unencrypted traffic · **the sealed note =** encrypted traffic · **seeing who passed it =** traffic analysis

T TAXILA

Student Wi-Fi traffic is readable unless the service uses secure connections.

× COMMON MISTAKE

I would notice if someone were sniffing.

Passive sniffing sends nothing and leaves no trace; encrypt instead.

CONCEPT 2

Scanning and reconnaissance

A scan of the server room's segment shows what is exposed.

TRY IT FIRST

A host's services as doors: open, closed or filtered.

30 min

Demonstration: the corridor of doors

1. Choose a door in the outside view
2. Find the line behind it in the server's own list
3. Read what the defender should do
4. Show the door the outside cannot see

The finding is the door that should not be open.

Three answers a port can give

open
a service answered

closed
the machine said nothing listens

filtered
no answer came back

Port	Outside view	Behind it
22	open	sshd, remote login
25	closed	nothing listens
443	open	apache2, the portal
3306	**open**	**mariadbd, the database**
8080	filtered	python3, a forgotten test copy

A defender maps the doors first

- Attackers **scan** first, to map the doors before trying them
- A defender keeps an **inventory** of every listening service
- Compare it with what the **outside** actually sees
- Without written permission, scanning is an **offence**

Computer Crime Act, No. 24 of 2007: access without lawful authority.

Trying each door handle

YOU ALREADY KNOW THIS

Someone walks a corridor and tries each door handle in turn.

MAPPING

a handle that turns = an open port · **a handle that does not move =** a closed port · **a handle behind a locked gate =** a filtered port

T TAXILA

The outside view shows the SIS database port, 3306, open to the student Wi-Fi.

× COMMON MISTAKE

A scan is harmless, so it needs no permission.

Scanning a system you do not own, without permission, is an offence.

CONCEPT 3

Interception and address poisoning

A poisoned cache on the staff network could intercept a login.

TRY IT FIRST

A false address reply poisons a cache, by capture only.

30 min

Demonstration: trusting the first answer

1. Step through the question and the gateway's answer
2. Watch the laptop's address cache fill in
3. Step to the reply nobody asked for
4. Read what the defender sees

One address, two hardware addresses: that is the pattern.

How a machine gets into the middle

- A **machine in the middle** relays traffic both sides think is direct
- **ARP**, the Address Resolution Protocol, maps an IP address to a hardware address
- A machine asks the whole segment; the owner **replies**
- ARP has **no check** on who answers
- A false reply **poisons** the cache, and traffic goes to the wrong machine

Studied by concept and capture only. Never performed.

What a defender sees in the capture

- Frame 2: `10.10.0.1 is at 02:00:0a:0a:00:01`, the gateway
- Frame 6: `10.10.0.1 is at 02:00:0a:0a:00:42`, unasked
- Wireshark: **Duplicate IP address configured**
- Frame 7: the next request goes to the **wrong** machine

Secure web still protects the content: the certificate check fails.

Trusting the first voice

YOU ALREADY KNOW THIS

A messenger gives the letters to the first voice that answers. An impostor answers, reads them and hands them on.

MAPPING

trusting the first voice = ARP trusting any reply · **the impostor relaying =** the machine in the middle

T TAXILA

A poisoned cache on the staff network could intercept a login.

× COMMON MISTAKE

Address poisoning comes from somewhere on the internet.

It needs a machine on the same segment.

CONCEPT 4

Firewalls and intrusion systems

A firewall between the student wireless network and the servers; monitoring that notices the unusual.

TRY IT FIRST

Prepared traffic tested against three firewall kinds.

30 min

Demonstration: three kinds of firewall

1. Choose the packet filter and send the four items
2. Switch to the stateful firewall, then the application layer
3. Let the application layer end the encryption
4. Place an intrusion system in and out of the path

Each kind adds one thing it can check.

Firewalls grew in three steps

Gen 1

Packet filter

Checks each packet alone, by address, port and protocol. Keeps no memory.

Lets a fake reply flood through.

Gen 2

Stateful firewall

Also remembers every connection opened through it.

Drops replies to connections nobody opened.

Gen 3

Application layer

Also reads the content. A web application firewall (WAF) is this kind.

Can see an injection string in plain web.

None of them reads inside encryption it does not **end** itself.

Denial of service

- A **denial of service** floods a service so real users cannot reach it
- A **distributed** denial of service uses many machines at once
- Blocking one sender does not stop a distributed flood
- It attacks **availability**, the property from Day 1

A stateful firewall drops replies that belong to no connection.

Detection and prevention

Out of the path, IDS

Intrusion detection system

- Watches a copy of the traffic
- Raises an **alert**; traffic still flows
- Someone must read the alert and act

In the path, IPS

Intrusion prevention system

- Sits where the traffic passes
- **Blocks** what it recognises
- A false alarm blocks real users too

Both recognise by signature (known patterns) or anomaly (far from normal).

Three door checkers

YOU ALREADY KNOW THIS

One checker looks at each person. A second also keeps a guest list. A third also searches every bag.

MAPPING

looking at each person alone = a packet filter · **the guest list =** tracking connection state · **searching the bag =** reading the payload

T TAXILA

A firewall between the student wireless network and the servers; monitoring that notices the unusual.

× COMMON MISTAKE

A firewall reads encrypted payloads.

Only if it ends the encryption itself; otherwise the payload is opaque.

CONCEPT 5

Zones, private tunnels and depth

Student wireless kept apart from staff and servers; Kandy reaching the SIS through a private tunnel.

TRY IT FIRST

A compromised web server contained by the inner firewall.

30 min

Demonstration: zones and the demilitarised zone

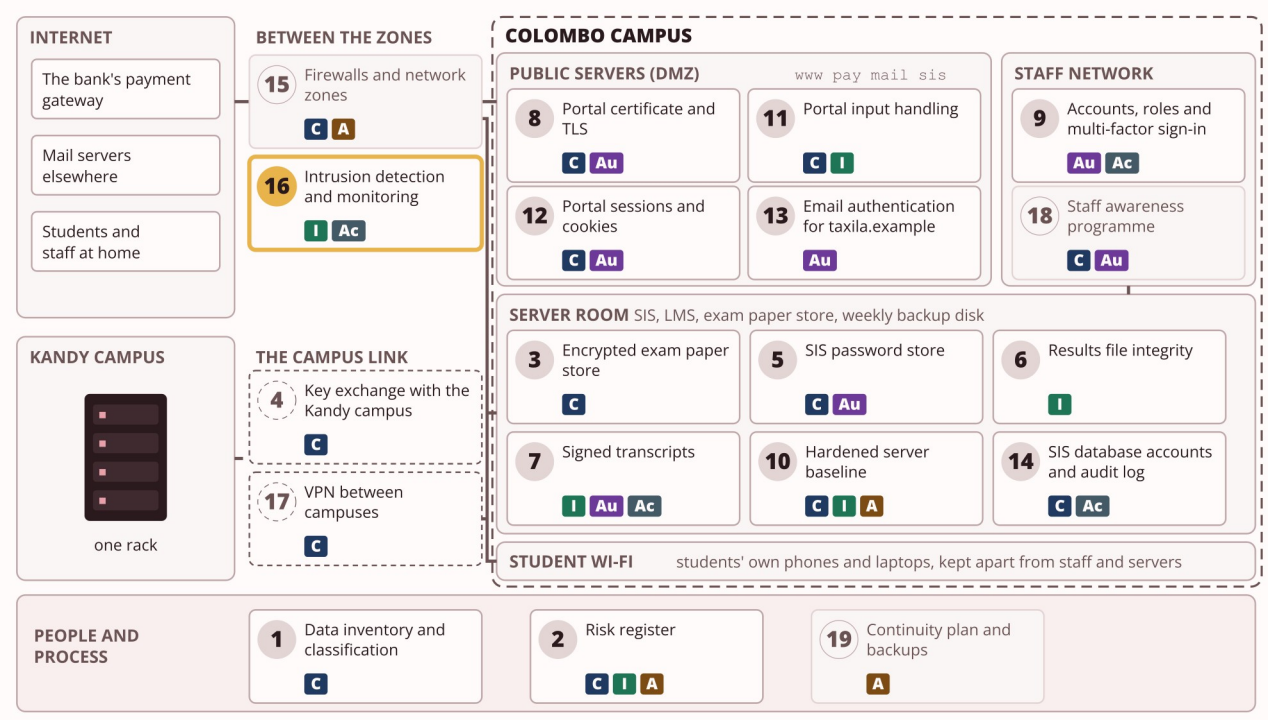
1. Move each server into a zone
2. Mark the website as broken into
3. Remove the inner firewall and look again
4. Send Kandy's traffic through the tunnel

The inner firewall contains a broken public server.

Three tools for zones

- **Segmentation** groups machines by trust, with a firewall between
- A **demilitarised zone** (DMZ) holds public servers between two firewalls
- **VLANs**, virtual local-area networks, split shared wiring into separate networks
- A **virtual private network** (VPN) carries traffic in an encrypted tunnel
- IPsec or TLS does the tunnel's encrypting

The security register



TODAY

16 Intrusion detection and monitoring

17 VPN between campuses

KEY

- Added earlier
- Demonstrated
- Concept only
- Not yet added

A hospital and its wards

YOU ALREADY KNOW THIS

Anyone may walk into reception. The wards are locked, and a guarded corridor joins the second building.

MAPPING

the public reception = the demilitarised zone · **locked ward doors =** segmentation · **the secure corridor =** the virtual private network

T TAXILA

Kandy reaches the SIS through a private tunnel rather than the open internet.

× COMMON MISTAKE

A server in the demilitarised zone is inside, so it can be trusted.

It is the most exposed server; the inner firewall treats it as untrusted.

Defence in depth, on the network

1. A hardened server runs only what it needs
2. A firewall in front of it drops the rest
3. A separate zone limits how far trouble spreads
4. Encryption on the wire defeats the watcher
5. Monitoring notices what gets through

Each layer covers a failure in another.

Common mistakes

× COMMON MISTAKE

I would notice if someone were sniffing.

Passive sniffing leaves no trace.

× COMMON MISTAKE

A scan is harmless, so it needs no permission.

Without permission, scanning is an offence.

× COMMON MISTAKE

A firewall reads encrypted payloads.

Only if it ends the encryption itself.

Back to the open door

The SIS database answers the student Wi-Fi on port 3306. Name three independent layers that would each have stopped that, and say which one you would fix first.

Before the next day

READ	**Security in Computing, chapter 6** Sections 6.2, 6.4 to 6.8
PRACTICE	**A courier company's tracking site** Shared-network threats, firewalls and a demilitarised zone
TASK	**Your group's controls map** Add network threats and defences

Questions & Discussion

This afternoon: inventory your services, write a firewall rule, read address traffic.



Disclaimer & Copyright

The information in this presentation is for general teaching purposes only. It is not comprehensive and is not professional advice; any reliance you place on it is at your own risk. I aim to keep it accurate, but I make no representations or warranties of any kind about its completeness, accuracy, reliability or suitability.

Security tools, standards and laws change. Versions, editions and commencement dates in this presentation were checked at the time of writing; check the current documentation before relying on them.

This presentation may refer to third-party websites or content. I do not endorse their views or information, and I am not responsible for their content.

Taxila College is fictional. Its campuses, people, systems and incidents were invented for teaching. Product and tool names, for example Kali Linux, VirtualBox, CyberChef and Wireshark, belong to their owners; this material is not affiliated with or endorsed by any of them.

Practise only on your own virtual machine, the module's provided files and application, and the portal's demos. Testing a system you do not own, without written permission, is an offence under Sri Lanka's Computer Crime Act, No. 24 of 2007.

© Niranga Dharmaratna, School of Computing & Engineering, National Institute of Business Management. Teaching content under CC BY-NC-SA 4.0; code and demonstrations under MIT; Open Sans under the SIL Open Font Licence.

Revision be8ad06